

# Top 10 Web Hacking Techniques of 2017



**James Kettle**  
Director of Research  
[@albinowax](#)



**Published:** Thursday, 11 October 2018 at 14:40 UTC

**Updated:** Tuesday, 5 January 2021 at 14:10 UTC



The verdict is in! Following [37 nominations](#) whittled down to a shortlist of 15 by a community vote, our panel of experts has conferred and selected the top 10 web hacking techniques of 2017 (and 2016).

The panel consisted of [myself](#), and distinguished researchers [Gareth Heyes](#), [Nicolas Grégoire](#), [Frans Rosén](#), and [Soroush Dalili](#). Our objective is to spread awareness of the techniques, and also help prevent them from being forgotten in coming years. As such, we've evaluated the 15 nominees by how innovative, widespread and impactful the findings are, and how long they will continue to be relevant. The top three results in particular are unanimously regarded as must-read articles by the entire panel.

We initially decided to prevent conflicts of interest by excluding PortSwigger research, but after we decided to have a broad voting panel it became clear we needed a better system. We eventually settled on disallowing panelists from voting on research they're affiliated with, and adjusting the final scores to

compensate. Of course by then it was too late to reintroduce PortSwigger research, so we'll never know what the likes of [Cracking the Lens](#) and [XSS without HTML](#) would have scored ;)

We'll run through the results starting at 10th place and building towards the best research of the year:

## 10. Binary Webshell Through OPcache in PHP 7

In this [blog post](#) from 2016, [Ian Bouchard](#) unveils a novel technique to bypass hardening and successfully obtain RCE via file write vulnerabilities on systems running PHP 7.

## 9. Cure53 Browser Security Whitepaper

In this [enormous whitepaper](#) commissioned by Google, [Cure53](#) take an in depth look at the security of Internet Explorer, Edge and Chrome. Chapters 3-5 in particular contain some interesting web security lore.

## 8. Request Encoding to bypass web application firewalls

In which [Soroush Dalili](#) does some crazy stuff with encoding and malformed HTTP requests to dance around numerous WAFs. Unfortunately a recording of the presentation isn't available, but it can be pieced together from [two blog posts](#) and the updated [slides](#).

## 7. A deep dive into AWS S3 access controls

In [A deep dive into AWS S3 access controls](#), [Frans Rosén](#) examines the inner workings of S3 buckets from both an attacker's and defender's perspective. It covers numerous common pitfalls including the amazing and hilarious 'AuthenticatedUsers' gotcha.

## 6. Advanced Flash Vulnerabilities

This [series of blog posts](#) by [Enguerran Gillier](#) uses a series of vulnerabilities in YouTube to introduce and illustrate several advanced Flash exploitation techniques. He's combined numerous often overlooked techniques with artistic flair in these exceedingly well explained posts.

## 5. Cloudbleed

This slightly off-beat entry by [Tavis Ormandy](#) flouts common conceptions of what research should look like - it was discovered by accident, only affects one vendor, and barely requires active exploitation. Nevertheless, it clearly had a huge impact, and is going to leave many people keeping an eye open for memory disclosure for the foreseeable future.

In addition to the [original bug report](#), it's also worth reading [Cloudflare's post-mortem](#), although beware that as Tavis warns it "severely downplays the risk to customers".

## 4. Friday The 13th JSON Attacks

Following on from the Java [Deserialization](#) Apocalypse in 2016, [Alvaro Muñoz](#) & Oleksandr Mirosh performed a comprehensive analysis of numerous JSON (de)serialization libraries for Java and .NET, providing an ongoing supply of RCEs for the rest of us. It's available both as a [presentation](#) and [whitepaper](#).

## 3. Ticket Trick

[Ticket Trick](#) is an inventive technique by [Inti De Ceukelaire](#) abuses issue trackers and support centers to break into systems that implicitly trust all email addresses ending in a certain domain. It's a beautiful example of how independent systems can be completely secure in isolation but fall apart when combined, and we expect this to be an effective technique for years to come.

It's also the only entry in the top 3 with a logo, although I'm not sure it deserves any credit for that.

## 2. Web Cache Deception

Hackers have been poisoning web caches with malicious content for years, but [Omer Gil](#) took this technique and flipped it on its head, finding a way to manipulate web caches into saving other user's sensitive data, and demonstrating it on Paypal. Available as both a [presentation](#) and [whitepaper](#), [Web Cache Deception](#) is a powerful and imaginative technique that still works on multiple major caches, and I suspect will provide a platform for further research in years to come.

Finding genuinely new techniques is getting more difficult as [application security](#) matures, so it's refreshing to see people prove year after year it's still possible.

## 1. A New Era of SSRF

[A New Era of SSRF](#) by [Orange Tsai](#) advances the state of the art of [SSRF](#) exploitation with an iceberg of inventive techniques for bypassing SSRF defences and maximising the resulting impact. Described as "impactful and innovative" by [Agarri](#) who [knows a bit about SSRF](#) himself, [the slides](#) are squeezed with exploits making it well worth a second or third read-through.

It also features one of the best exploit chains I've ever seen, and is enough to put anyone off fetching user-supplied URLs forever. A well deserved number one.

We've since built a [Web Security Academy lab](#) where you can try applying this research for yourself.

## Runners up

A few runners up that didn't quite make it into the top 10 deserve an honourable mention. The [X41 Browser Security whitepaper](#) is a solid resource but light on web research, and [\\$10k host header](#) is shiny but more of an elegant application of a known technique than fresh research. I really like [Hiding Wookies in HTTP](#) but completely forgot to nominate it, and [Don't trust the DOM](#) might have scored quite highly from the panel, but didn't quite survive the community vote.

## What next?

This year was a bit experimental but it's gone well and we have numerous ideas on how to improve the process for next year. There were some suspicious voting patterns that made us glad we enforced Google sign-in, and we plan to build a custom voting platform next year to further mitigate this and make voting easier. We'll also be able to avoid excluding any research, and initiate the process immediately in January 2019 when the research is still fresh in people's minds. In fact we've already [opened for nominations](#) for 2018. If you're wondering how to invent a technique that will land you in next year's list, I've published a [guide on how to become a web security researcher](#).

Many thanks to the panellists for contributing their time and expertise, [Matt Johansen](#) and [Jeremiah Grossman](#) for their support with the transition, and the wider community for the many nominations and votes.

Update: the [Top 10 Web Hacking Techniques of 2019](#) is now out.

[top-10-techniques](#)

[Top 10 Hacking Techniques](#)

[← Back to all articles](#)

## Related Research



### Burp Suite

Web vulnerability scanner  
Burp Suite Editions  
Release Notes

### Vulnerabilities

Cross-site scripting (XSS)  
SQL injection  
Cross-site request forgery  
XML external entity injection  
Directory traversal  
Server-side request forgery

### Customers

Organizations  
Testers  
Developers

### Company

About  
Careers  
Contact  
Legal  
Privacy Notice  
Modern Slavery Statement

### Insights

Web Security Academy  
Blog  
Research  
Engineering



[Follow us](#)

© 2026 PortSwigger Ltd.

